

Fullsoft INC.

Security for your health

Presentation to Leadership

ISDA-123 | Professor Frank Cervone | Final Project | Alex Williams

Introduction



Outlining regulations and law requirements



Our recommended risk assessment methodology



Learning from our malware attack and security breach



The plan for our gap analysis



Countermeasures to prevent future incidences

Fullsoft Must Follow Laws and Regulations

Health Insurance Portability and Accountability Act (HIPAA)

- Fullsoft develops **healthcare software**
- Healthcare software collects healthcare information
- HIPAA protects healthcare information of the users
- Penalties in not complying with HIPAA include hefty fines

Sarbanes-Oxley Act (SOX)

- Fullsoft is publicly traded
- SOX requires that companies report accurate financial disclosures
- Annual audit reports must be made to protect stakeholders from fraud

Payment Card Industry Data Security Standard (PCI DSS)

- Fullsoft applications require payment processing cards
- PCI DSS protects payment card information
- It uses control layers involving the life cycle of payment card data

Gramm-Leach-Bliley Act (GLBA)

- Fullsoft software collects personally identifiable consumer financial information
- GLBA involves documenting how user data is collected
- Consumers are given more power to opt out of specific types of data collection

For The Future: More Laws and Regulations

California Consumer Privacy Act & Rights Act (CCPA/CPRA)

- Applies to Californians who may use Fullsoft software
- Requires transparency over how data collection is performed
- Gives users the ability to access their data, delete, and have other opt-out options available

General Data Protection Regulation (GDPR)

- Expansion in Europe requires following the strictest compliances
- Protects the entire life cycle of user data
- Gives control for users in how data should be accessed and deleted

Children's Online Privacy Protection Act (COPPA)

- Minimizes data collection of children under 13 years old
- Requires verified parental agreements before data collection
- Privacy policy statements must be made clear

Utilizing an Information Security Policy Framework (ISPF)



- Provides an information security management system (ISMS) aligned to Fullsoft's needs
- Aligns with the compliance of relevant regulations (HIPAA, SOX, PCI DSS)
- Focuses on risk mitigations of businesses (user data, system maintenance, intellectual property)
- Complies with the cyber security principles of confidentiality, integrity, and availability (CIA)
- Continuously improves assessment and monitoring using a Plan-Do-Check-Act (PDCA) cycle
- Considered the gold standard of ISPFs

Learning From The Malware Attack and Security Breach

What Happened	What Changes
• An employee brings an unauthorized universal serial bus (USB) with malware on it.	• Employee training changes, including policies on outside external storage devices.
• An unprotected workstation computer with exposed inputs boots the unknown USB.	• Employee workstations have higher physical access control protocols.
• Lack of both physical and digital access control allows the USB to open and run.	• Only authorized whitelisted programs and applications can run.
• Antimalware and other antivirus software protection does not catch the malware.	• Antimalware and antivirus software is always updated and running.
• The malware infects Fullsoft's computer network and steals proprietary information.	• Network segmentation is implemented to safeguard against unauthorized access.

The Plan to Developing a Gap Analysis

Objectives

- **Implement ISO/IEC - 27002** to understand and apply best practice recommendations
- **Evaluate role performances and processes** within the Fullsoft's overall IT and Cybersecurity teams (particularly our confidential product development code)
- **Gathering and assess information** regarding the functions of our current security system and cross compare with ISO/IEC - 27002
- **Deeply analyze** our security program and use SWOT analysis to identify strengths, weaknesses, opportunities and threats

Goals

- Identify our current practices with the ISO/IEC - 27002 best practices and meet its standards
- Increase better workflows, processes, security improvements, and employee training to reduce risks and build stronger security
- Meet compliances standards and build an action-plan to keep consistent and up-to-date with the changing security atmosphere

Integrating Continuity Planning Into Our Gap Analysis

- **ISO 27001** includes a Business Continuity Plan (BCP) to address procedures during an incident
- This continuity plan **helps guide us to what we should do during an incident** (like our data breach)
- BCPs helps **define the roles and responsibilities in teams** and what actions they should take in an incident
- Includes specific remediations for **how Fullsoft will continue operations** based off task prioritizations
- Helps establish a timeline and how to maintain communication efforts between employees during a crisis
- Reflects upon defining a process once the incident finishes

Immediate Countermeasures We Can Use



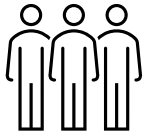
Conduct a digital forensics investigation.



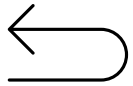
Avoid tampering with the malware infected workstation.



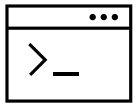
Perform a Cybersecurity Evaluation Tool (CEST) Assessment.



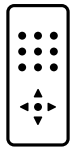
Hire cybersecurity experts to walk us through and teach us.



Establish a security baseline.



Install antimalware and update antivirus protection on all computers.



Install device control software.

References

(OCR), Office for Civil Rights. “Summary of the HIPAA Privacy Rule.” *HHS.Gov*, 14 Mar. 2025, www.hhs.gov/hipaa/for- professionals/privacy/laws-regulations/index.html.

“California Consumer Privacy Act (CCPA).” *State of California - Department of Justice - Office of the Attorney General*, 28 Jan. 2025, oag.ca.gov/privacy/ccpa.

“ISO/IEC 27001:2022.” *ISO*, 25 Oct. 2022, www.iso.org/standard/27001.

“ISO/IEC 27002:2022.” *ISO*, 1 Mar. 2022, www.iso.org/standard/75652.html.

“Legal Text.” *General Data Protection Regulation (GDPR)*, 22 Apr. 2024, gdpr-info.eu/.

Nguyen, Stephanie T. “Children’s Online Privacy Protection Rule (‘coppa’).” *Federal Trade Commission*, 3 Feb. 2023, www.ftc.gov/legal-library/browse/rules/childrens-online-privacy-protection-rule-coppa.

Nguyen, Stephanie T. “Gramm-Leach-Bliley Act.” *Federal Trade Commission*, 6 Feb. 2025, www.ftc.gov/business-guidance/privacy- security/gramm-leach-bliley-act.

“The Sarbanes Oxley Act.” *The Sarbanes Oxley Act*, sarbanes-oxley-act.com/. Accessed 18 Apr. 2025.

“Standards.” *PCI Security Standards Council*, 12 July 2024, www.pcisecuritystandards.org/standards/.